

Enterprise GRC Control Mapping

GDPR • ISO 27001 • ISO 42001 • DORA • NIS2

ENTERPRISE COMPLIANCE / GRC CAPSTONE CASE STUDY

Prepared by Nouman J.

Enterprise GRC • Cybersecurity • Compliance • Risk Management

Professional Portfolio Case Study

1. Executive Summary

This capstone models an integrated enterprise GRC operating model across five major frameworks. The objective is to reduce duplicated compliance effort while preserving framework-specific accountability, evidence requirements and risk decisions.

2. Business Context & Scope

A fictional multinational enterprise operates corporate IT, cloud services, AI-enabled processes and regulated business activities. Multiple compliance teams maintain overlapping controls and evidence, creating duplicated effort and inconsistent ownership. The case study demonstrates how a common-control model can provide structure without treating different frameworks as interchangeable.

3. Governance & Accountability

Role	Accountability
Executive / Management	Sets risk appetite, approves material risk decisions and oversees remediation.
GRC / Risk / Compliance	Maintains methodology, challenges risk assessments, coordinates mappings and reports aggregate exposure.
Common Control Owner Council	Coordinates shared controls, ownership, evidence standards and cross-framework consistency.
Framework Specialist	Provides subject-matter interpretation for privacy, information security, AI governance, ICT resilience or cybersecurity.
Business / Process Owner	Owns business risk and remediation outcomes.
Control Owner	Operates controls and maintains evidence.
Internal Audit	Provides independent assurance over governance and control effectiveness.

4. Integrated GRC Methodology

The operating chain is: Obligations → Risks → Common Controls → Framework Mapping → Evidence → Testing → Findings → Remediation → Management Reporting. A common control may support several frameworks, but each mapping requires explicit rationale and retains framework-specific accountability.

5. Control Architecture

The control model separates enterprise-wide controls from framework-specific requirements. Typical shared domains include identity and access management, incident management, supplier risk, vulnerability management, business continuity, asset management, data protection and governance. Mapping decisions are documented rather than assumed.

6. Risk Register

Risk ID	Risk Scenario	Likelihood (L)	Impact (I)	Inherent Risk	Risk Level	Primary Treatment	Residual Risk
GRC-01	Duplicated control ownership	4	4	16	Critical	Common-control ownership and RACI	6
GRC-02	Evidence cannot support assurance requests	3	4	12	High	Evidence index, metadata and standards	4
GRC-03	Regulatory change is not reflected in controls	3	5	15	Critical	Regulatory change process	6
GRC-04	AI governance is disconnected from wider GRC	3	4	12	High	Integrated AI, privacy and security governance	4

7. Gap Analysis & Findings

Finding	Area	Severity	Observation	Recommended Action
F-01	Control ownership	High	Framework teams duplicate activities because common-control accountability is fragmented.	Common control owner council.
F-02	Evidence reuse	High	Evidence is stored without consistent cross-framework metadata.	Metadata evidence-as-a-control operating model.
F-03	Regulatory change	High	Regulatory changes are manually tracked and impact assessment is inconsistent.	Quarterly regulatory-change review and impact assessment.

8. Remediation Roadmap

0–30 days: establish common-control ownership, validate material mappings and address critical gaps.

31–90 days: standardise evidence metadata, testing criteria and exception handling.

91–180 days: automate evidence collection and regulatory-change impact assessment.

181–365 days: operate continuous cross-framework assurance and management reporting.

9. KPI / KRI Management View

- Controls with accountable owner: 100%
- Evidence reused across applicable frameworks: >60%
- Overdue regulatory-change assessments: 0
- High-risk remediation completed on time: >90%

10. Evidence & Assurance

A production implementation would link each common control to accountable ownership, mapped obligations, evidence sources, testing results, exceptions and remediation actions. Evidence reuse should improve efficiency without weakening framework-specific assurance.

11. Management Conclusion

An integrated GRC model is valuable when it reduces duplication while making risk ownership clearer. The capstone demonstrates how one control can support multiple obligations, while still requiring explicit mapping logic, evidence quality and management accountability.

12. Portfolio Disclaimer

Synthetic professional case study for portfolio demonstration. It does not represent a real client engagement, audit opinion, certification or production implementation.